

Using CISA's Cybersecurity Performance Goals in Hyperproof

Best Practices

This guide is intended to help organizations using Hyperproof implement the NIST Cybersecurity Framework (CSF) based on recent optional, prioritized guidance from the Cybersecurity and Infrastructure Security Agency (CISA).

What is NIST CSF?

The NIST CSF not only helps organizations understand their cybersecurity risks (threats, vulnerabilities, and impacts), but how to reduce these risks with customized measures. The framework also helps them respond to and recover from cybersecurity incidents, prompting them to analyze root causes and consider how they can make improvements. Companies from around the world have embraced the use of the framework, including JP Morgan Chase, Microsoft, Boeing, Intel, Bank of England, Nippon Telegraph and Telephone Corporation, and the Ontario Energy Board. (source: [Cybersecurity Framework | NIST](#))

The CISA Cybersecurity Performance Goals (CPG) are a prioritized subset of IT and operational technology (OT) cybersecurity practices that critical infrastructure owners and operators can implement to meaningfully reduce the likelihood and impact of known risks and adversary techniques. The goals were informed by existing cybersecurity frameworks and guidance, as well as the real-world threats and adversary tactics, techniques, and procedures (TTPs) observed by CISA and its government and industry partners. By implementing these goals, owners and operators will not only reduce risks to critical infrastructure operations, but also to the American people. (Source: [Cross-Sector Cybersecurity Performance Goals | CISA](#))

About This Guide

The attached guide is a suggested workflow for both novice and expert compliance professionals looking to implement NIST CSF. You'll find an overview of each step as well as instructions on how to complete those steps using Hyperproof. This is an interactive guide; all links and images are clickable.

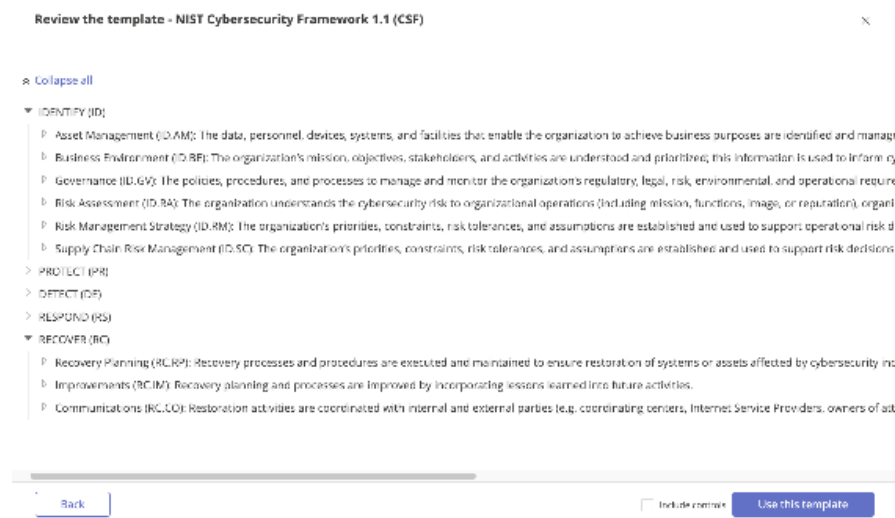
Using CISA's Cybersecurity Performance Goals in Hyperproof

Best Practices

Overview

STEP ONE: GETTING STARTED

The first step to working with NIST CSF and CISA's CPGs in Hyperproof is to create your program. If you've completed a SOC 2 or ISO 27001 program in Hyperproof, for example, you can [jumpstart](#) your NIST CSF program from your SOC 2 or ISO 27001 program.



How to in Hyperproof

1. From the left navigation menu, select *Programs*.
2. Click **New**.
3. Search for NIST CSF and then select the program template.
4. Click **Review**.
5. Review the template.
6. If you want to use Hyperproof's illustrative controls, select the **Include controls** checkbox. If you want to use your own controls, leave the checkbox unchecked. Click **Use this template**.
7. Name your program and, optionally, provide a description of it.
8. Click **Create program**.
9. If you are using Hyperproof's illustrative controls, click **Finish**. If you are importing your own controls, click **Upload Controls**. If you clicked **Upload Controls**, follow the steps in the article, [Importing Controls](#), to successfully import your controls in to Hyperproof.

Overview

STEP TWO: CONDUCTING A PRIORITIZED GAP ANALYSIS

Using the [CISA CPG checklist](#) and Hyperproof, locate evidence (policies, procedures, standards, and guidelines) that supports each one of the practices in the CPG.

Where there is adequate evidence available, mark controls as *Completed*. For example, item 1.1, *Detection of Unsuccessful (Automated) Login Attempts*, in the CPG checklist maps to NIST CSF control PR.AC-7. If your organization has a process or supporting technology for detecting unsuccessful failed login attempts, mark PR.AC-7 as *Completed* for now.

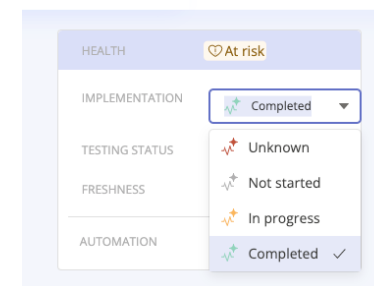
Where there is no adequate evidence available, mark controls as *Unknown* in Hyperproof. Continue until all items from the CISA CPG checklist have been evaluated and the controls in Hyperproof updated to reflect the appropriate implementation status.

Note that the CPG only covers about one-third of the available controls in NIST CSF (33 of 108). However, according to CISA, these are potentially the highest impact controls organizations should consider strengthening or implementing first before moving to additional controls.

If all 33 controls are covered, skip
Step Four: Automating Evidence Collection.

How to in Hyperproof

1. From the left navigation menu, select *Controls*. Optionally, click the **Filter** icon to filter controls by program.
2. Click the **Grid view** icon in the upper-right corner.
3. Select the checkbox next to the control(s) you want to implement.
4. Click **Implementation** and then select *Completed* for controls with sufficient evidence or *Unknown* for controls without sufficient evidence.



Overview

STEP THREE: PRIORITIZING INITIAL CONTROL GAP MITIGATIONS

Based on your organization's budget and staffing levels, focus on deploying controls (people, processes, technologies) that are aligned to the CPG checklist where the implementation status in Hyperproof is *Unknown*.

For example, if PR.AC-1, *Identities and credentials are issued, managed, verified, revoked, and audited for authorized devices, users and processes*, had an implementation status of *Unknown* in Hyperproof, consult the guidance in the CPG (item 1.4) that shows this has a high reduction of risk and a low cost.

The CPG provides a "recommended action" to take for controls with an implementation status of *Unknown*. In the example above, PR.AC-1, the recommendation is as follows:

Organizations have a system-enforced policy that requires a minimum password length of 15 or more characters for all password protected IT assets, and all OT assets where technically possible.** Organizations should consider leveraging passphrases and password managers to make it easier for users to maintain sufficiently long passwords. In instances where minimum password lengths are not technically feasible, compensating controls are applied and recorded, and all login attempts to those assets are logged. Assets that cannot support passwords of sufficient strength length are prioritized for upgrade or replacement.*

Use Hyperproof's [task feature](#) to assign owners to those NIST CSF controls that meet your organization's tolerance for expenses and effort. Track control gap mitigation activities via the task.

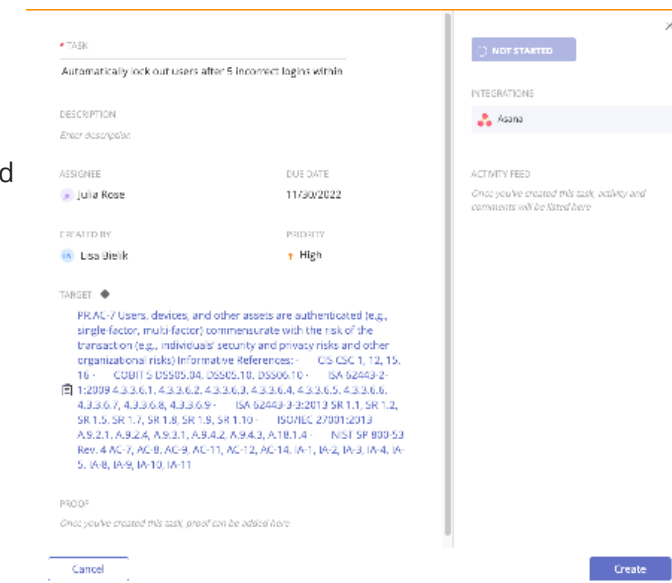
Remember to mark each control status as *Implemented* in Hyperproof after there is adequate evidence of practice. Refer to *Step Two: Conducting a Prioritized Gap Analysis* above.

How to in Hyperproof

1. From the left navigation menu, select *Controls*. Optionally, click the **Filter** icon to filter controls by program.
2. Select the control you want to create a task on.
3. Click the **Task** icon in the upper-right corner.
4. Click **New Task**.
5. Enter the necessary information in the *Task* modal, including an assignee and due date.
6. Click **Create**.

A few notes on tasks:

1. Existing Jira or Asana issues can be attached to the task, or new issues can be created in either Jira or Asana based on the task.
2. The task's status can be changed once the task is created.
3. Proof can be linked to the task once the task is created.
4. You can communicate and collaborate with other team members via the task's Activity Feed once the task is created.



Overview

STEP FOUR: AUTOMATING EVIDENCE COLLECTION

For items that either had evidence prior to the prioritized gap analysis, or have had new controls (people, process, technology) applied, use a combination of Hyperproof's Hypersync and LiveSync features to regularly inspect each control.

Live documents (i.e. documents edited in real-time), such as policies and procedures, are great candidates for LiveSync. For example, a LiveSync could regularly collect new versions of your organization's cybersecurity policy document(s) relevant to ID.GV-1, *Organizational cybersecurity policy is established and communicated*.

Items that are potential candidates for Hypersync are the technical implementations of controls. For example, PR.AC-1 (mentioned above) requires a minimum password strength. If your organization uses AWS for Identity and Access Management, you could use the AWS IAM: Account Password Policy Hypersync to collect the password policy as configured on a periodic basis. This would prove that the implementation matches the policy as potentially defined under ID.GV-1.

Note that creating a connection (Hypersync) between Hyperproof and a service app requires you to have a certain level of permissions in the service app. Each service app is different and some are more complex than others. Prior to setting up the Hypersync, consult with your service app's Administrator to ensure that you have sufficient privileges. For more information on supported service apps, including permissions, please refer to [the Help Center](#).

How to in Hyperproof

Turning on LiveSync

1. Ensure that Hyperproof is connected to the integration, e.g. Google Drive or Dropbox. For more information on how to do this, please refer to [the Help Center](#).
2. From the left navigation menu, select *Controls*. Optionally, click the **Filter** icon to filter controls by program.
3. Select the control that you want to link proof to.
4. Select the *Proof* tab and then click **Add proof**.
5. Select the file(s) or folder(s) you want to link. Note that folder sync works with Drive, Sharepoint, OneDrive, and OneDrive for Business.
6. Toggle on **LiveSync** to automatically keep your proof up-to-date.
7. Click **Add proof**.

Setting up a Hypersync

1. From the left navigation menu, select *Controls*. Optionally, click the **Filter** icon to filter controls by program.
2. Select the control for which you want to automate proof.
3. Select the *Automations* tab and then click **Create Hypersync**.
4. Select your service app and then follow the prompts to connect Hyperproof to the app.
5. Once Hyperproof is connected to the service app, select the type of proof you want to collect and then click **Next**. Note that menus vary depending on the app.
6. Select how often you want to collect proof and a proof format, and then click **Next**.
7. Enter a name for the Hypersync and then click **Save and Sync**.

Please refer to [the Help Center](#) for more in-depth instructions for each supported service app.

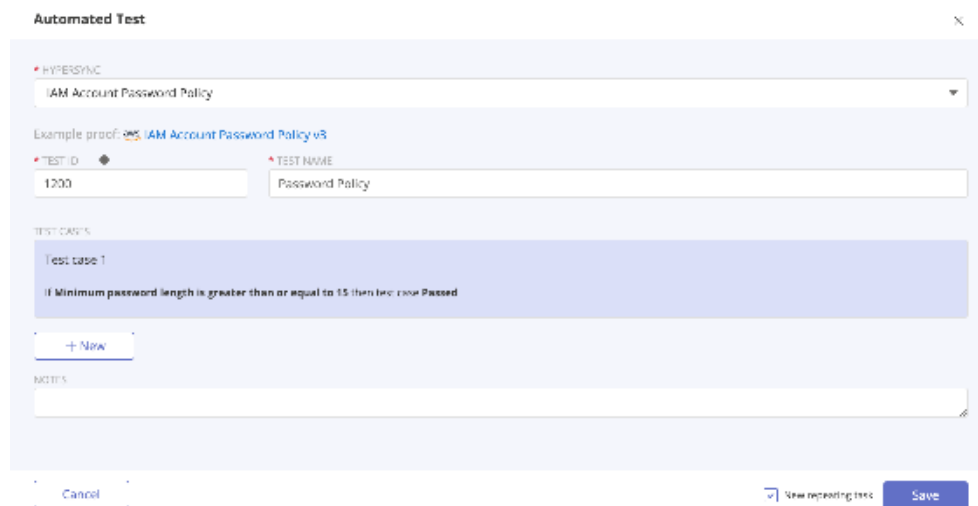
Overview

STEP FIVE: AUTOMATING CONTROL TESTING

Controls that have linked Hypersyncs can leverage automated control testing (ACT) to reduce the human effort required to validate the control effectiveness.

For example, if the organizational policy (ID.GV-1) requires a minimum password policy of 15 characters (per CPG 1.4), and the organization uses AWS' IAM services, and there is a configured Hypersync for the Account Password Policy, an ACT could be constructed to validate the minimum password length is 15 characters. This automates the testing process and eliminates the arduous task of manually testing the control.

Another example would be if the organizational policy requires vulnerability scans to be performed on a regular basis. Let's say the organization uses Qualys, and they've configured a Hypersync for the *List of PC Scans* proof type. An automated control test could be constructed to validate that the scans are taking place on the required cadence.



How to in Hyperproof

1. From the left navigation menu, select *Controls*. Optionally, click the **Filter** icon to filter controls by program.
2. Select the control for which you want to automate.
3. Select the *Tests* tab and then click **New test**.
4. From the *Hypersync* drop-down menu, select the appropriate Hypersync. Note that the control must have a linked Hypersync in order for automated testing to work!
5. Enter an ID and a name for the test.
6. Create the test case. If you need to add additional conditions, click **Add another condition**. If you need to add additional test cases, click **New**.
7. By default, Hyperproof links a repeating task to the main object, i.e. the control or label. If you don't want to create a repeating task, deselect the **Repeating task** checkbox.
8. Click **Save**.

Please refer to [the Help Center](#) for in-depth instructions.

Overview

How to in Hyperproof

STEP SIX: COMPLETING THE INITIAL PRIORITIZED CONTROL GAP MITIGATIONS

Continue implementing controls and validating them until the initial set of 33 NIST CSF controls (prioritized by CPG) have a status of *Completed* in Hyperproof.

Celebrate! (briefly)

- 1. From the left navigation menu, select *Controls*. Optionally, click the **Filter** icon to filter controls by program.
- 2. Click the **Grid view** icon in the upper-right corner.
- 3. Select the checkbox next to the control(s) you want to implement.
- 4. Click **Implementation** and then select *Completed*.

STEP SEVEN: CONDUCTING A GAP ANALYSIS OF THE REMAINING 75 NIST CSF CONTROLS

Evaluate each of the 75 remaining NIST CSF controls in Hyperproof based on the available supporting evidence. Mark controls where there is no evidence of practice as *Unknown* and those with sufficient evidence as *Completed*.

- 1. From the left navigation menu, select *Controls*. Optionally, click the **Filter** icon to filter controls by program.
- 2. Click the **Grid view** icon in the upper-right corner.
- 3. Select the checkbox next to the control(s) you want to implement.
- 4. Click **Implementation** and then select *Completed* for controls with sufficient evidence or *Unknown* for controls without sufficient evidence.

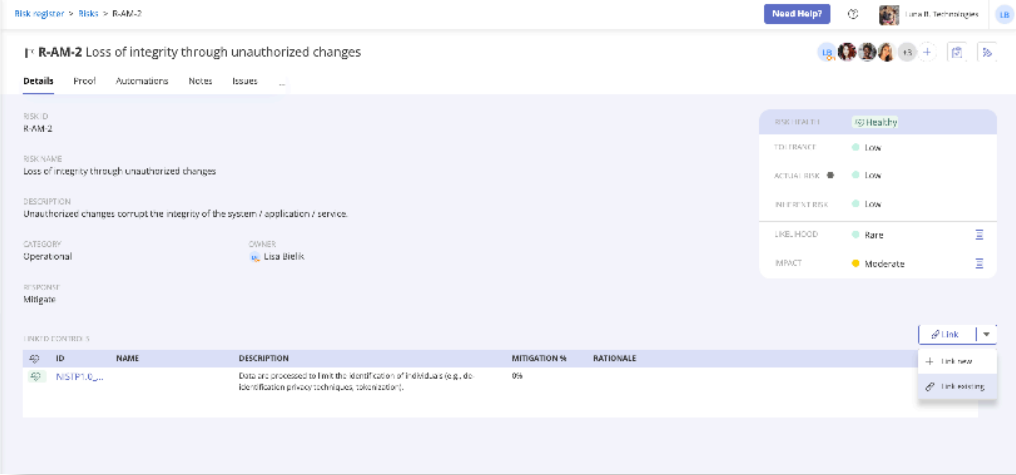
Overview

STEP EIGHT: PRIORITIZING GAP MITIGATIONS

Link your NIST CSF controls to your organization's risks. Based on the unique risks your organization faces and the organizational tolerance for budget and for complexity, prioritize implementation or maturity improvements to those NIST CSF controls that result in the most meaningful reduction of risk.

Mark new controls as *Completed* and automate the evidence collection process by setting up Hypersyncs, automated control tests, or LiveSync on the controls.

If your organization uses Hyperproof's Risk Register, update the decrease in risk based on the new or newly-improved controls. Refer to the steps to the right in the *How to in Hyperproof* section.



How to in Hyperproof

1. From the left navigation menu, select *Risk*.
2. Select the *Risks* tab.
3. Select the risk that you want to link to an NIST CSF control.
4. From the *Details* tab, click **Link** and then select *Link existing*.
5. Search for the control you want to link using the *Filter* panel.
6. Select the checkbox next to the control you want to link and then click **Link selected controls**.
Tip: If you're mitigating the risk, enter a [mitigation percentage](#). The percentage can be a whole number or a number with up to two decimals.

LINKED CONTROLS				
ID	NAME	DESCRIPTION	MITIGATION %	RATIONALE
ETSI422-4...		Core requirement A time-stamping client shall support the time-stamping response as defined in IETF RFC 3161 [1], clause 2.4.2 with the amendments defined in the following clauses.	30%	

7. Repeat steps 3 - 6 until all of your risks are linked to your NIST CSF controls.

Risk health automatically updates depending on the health of the linked control. For example, if the control is healthy, the risk will be healthy. If needed, you can manually adjust the health of a risk by mousing over a level, such as *Tolerance*, and clicking the **Pencil** icon.

For more information on risk health, please refer to [the Help Center](#).

Overview

How to in Hyperproof

STEP NINE: CONDUCTING AN ANNUAL RISK ASSESSMENT

Prioritize future control maturity efforts based on an internal or an external risk assessment of the unique risks that your organization faces. Hyperproof suggests conducting a risk assessment annually, at a minimum.

The linkage between NIST CSF controls and risks allows your organization to decide which controls effectively reduce risk to an acceptable level.

Currently, risks can be assessed in Hyperproof via the Risk Register. Be on the lookout for a risk assessment feature in the near future.

For assessing risks outside of Hyperproof, your organization should have a policy document that requires an annual internal or external risk assessment. The procedure document should detail how the risk management committee (or similar authorized party) would use Hyperproof as a part of conducting an annual risk assessment.